

SENTRY — Rapport d'avancement [Semaine 03/9 — complément du 06/10, soirée]

Date : 06/10/2026 · **Auteur :** Godwill FOKA (assisté par Claude) · **Jalon cible :** M2 constaté en CI, clôture de M7

Ce rapport complète 03_06-10-2026.md, rédigé le matin même.

1. Résumé exécutif

Un **clone neuf sur le poste Kali** a révélé quatre défauts invisibles en CI, dont un risque majeur : avec le .env de développement en place, scripts/ci-local.sh aurait vidé la base de travail (alembic downgrade base envoyé sur la mauvaise base). Les correctifs sont fusionnés dans main (595d425), avec 444 tests verts en CI. Les quatre clés externes (OTX, NVD, abuse.ch, RedEye) sont configurées : **le jalon M2 est atteint pour la première fois, en local et en CI** (validation réelle : scénario SOC 48/48, 7 sources saines, 67 495 IOC). Trois défauts de la collecte OTX sont identifiés ; leur correctif est la première tâche de la prochaine session.

2. Détail technique des tâches traitées

- ☒ **Installation sur Kali depuis un clone neuf** — démarrage rapide du README suivi pas à pas : .env.example copié tel quel, PostgreSQL et Redis (Docker Compose), migrations, rôle applicatif, comptes, API, scénario SOC. Volume PostgreSQL antérieur à M7 réutilisé : rôle sentry_app créé avec sentry db app-role sentry_app --create.
- ☒ **Branche fix/clone-neuf** (commit 595d425, 14 fichiers, +271 / -17) :
 - tests et ci-local.sh isolés du .env (nouvelle variable SENTRY_ENV_FILE) ; la suite refuse une MIGRATION_DATABASE_URL qui ne vise pas une base _test ;
 - variable vide = valeur par défaut (env_ignore_empty) : .env.example démarre tel quel ;
 - nouvelle commande sentry users set-password (politique ≥ 12 caractères, sessions révoquées, user.password_reset au journal d'audit) ;
 - sentry db init distingue « migration ratée » et « rôle applicatif manquant » ;
 - scénario SOC : arrêt explicite (code 2) sur API injoignable, comptes absents ou base vide ;
 - critère M3 renommé « Alerting : ligne de base établie » ;
 - CI : étape « clone neuf » (.env.example en place pendant les tests) ; guide d'exploitation (§ 1 bis, 3 bis, 7 bis) et CHANGELOG.
- ☒ **Fusion et synchronisation** — avance rapide de main sur GitHub et GitLab ; GitLab rattrape release/v0.1.1 et le tag v0.1.1 ; six branches déjà fusionnées supprimées de GitLab (dette D7 côté GitLab).
- ☒ **Clés externes** — OTX_API_KEY, NVD_API_KEY, ABUSECH_AUTH_KEY, TAXII_AUTH (RedEye et DigitalSide) dans le .env du poste et dans les secrets GitHub Actions.
- ☒ **Validation réelle lancée à la demande** avec les secrets (run du 06/10, 22:40) : verte.
- ☒ **Rattrapage OTX** — tentative de collecte complète (200 pages) échouée après 17 min ; source remise en état (HEALTHY, curseur reposé).
- ☐ **Correctifs de collecte** (curseur OTX, enregistrement page par page, message NVD) — prochaine session.
- ☐ **ADR-014 et préproduction VPS UE** — inchangés depuis le matin.

3. Validation sur données réelles

Mesure	Poste Kali (local)	GitHub Actions (CI)
Scénario SOC d'acceptation	48 / 48	48 / 48
Sources saines	7 / 9	7 / 9
IOC collectés	67 489 (759 confirmés par ≥ 2 sources)	67 495
OTX (20 pages)	29 245 IOC	29 245 IOC
URLhaus	31 168 URL	31 174 URL
RedEye (TAXII 2.1)	2 606 IOC (1 640 plages CIDR rejetées)	2 606 IOC
CVE	25 700 (KEV 1 734)	9 433 (KEV 1 734)
Couverture EPSS	98 %	94 %
Priorités P0 / P1 / P2 / P3	495 / 627 / 636 / 23 942	495 / 627 / 617 / 7 694
Chasse sur la base complète	—	56 062 IOC, 336 correspondances, 1,2 s

Jalons constatés par sentry status :

Jalon	Local	CI	Détail
M1 Foundation	✓	✓	schéma, API, rôles, audit
M2 Threat Feeds	✓	✓	≥ 500 IOC ✓, ≥ 3 sources ✓, OTX ✓, STIX ✓ — première fois
M3 Moteur CVE	✓	✓	NVD < 24 h, KEV ≥ 1 000, EPSS ≥ 90 %, ligne de base d'alerte
M4 Incidents	✓	✓	incident clos, 5 transitions tracées
M5 Dashboard	✓	✓	synthèse, activité, 8 exports (scénario)
M6 Hunting	✓	✓	2 sessions ; 339 correspondances en CI

4. Analyse SWOT de la journée

- **Forces** : M2 à M6 constatés en CI sur données réelles ; installation reproductible depuis un clone neuf ; la chasse produit enfin des résultats significatifs (339 correspondances contre 4) ; 759 IOC confirmés par plusieurs sources, base de la corrélation M8.
- **Faiblesses** : collecte « tout ou rien » (une page en échec annule la collecte entière) ; curseur OTX qui avance malgré une troncature ; pas de type « plage réseau » (CIDR rejetés).
- **Opportunités** : la validation hebdomadaire couvre désormais M2 ; les exports tiennent en CI (IOC : 3,5 s pour 67 000 lignes ; CVE : 0,7 s) ; set-password comble un manque d'exploitation.
- **Menaces** : sources publiques volatiles (DigitalSide toujours hors ligne, OTX lent sur les pages anciennes) ; volume d'IOC multiplié par 15 en une soirée, à surveiller avant la préproduction.

5. Problèmes rencontrés et solutions

Blocage	Impact	Solution adoptée	Statut
DOCS_ENABLED= et HSTS_ENABLED= vides dans .env.example	Application, tests et CLI ne démarrent pas	Variable vide = valeur par défaut	Résolu (595d425)
Les tests lisent le .env du poste	12 tests en échec en local	SENTRY_ENV_FILE= dans les tests et ci-local.sh	Résolu
MIGRATION_DATABASE_URL du .env vise la base de travail	ci-local.sh aurait vidé la base de travail	Isolation + garde-fou _test sur cette variable	Résolu
Rôle sentry_app absent (volume d'avant M7)	password authentication failed partout	sentry db app-role sentry_app --create ; message clarifié	Résolu
Compte admin hérité, mot de passe inconnu	Scénario en 401	Hash remplacé en SQL ; commande set-password ajoutée	Résolu
Scénario sur base vide	Trace IndexError	Arrêt explicite avec l'action à mener	Résolu
DNS de la VM momentanément indisponible	NVD et EPSS non synchronisés	Nouvelle tentative	Contourné
EPSS synchronisé avant NVD	Couverture 83 %	Synchronisation complète dans l'ordre KEV → NVD → EPSS	Résolu
Collecte OTX tronquée à 20 pages	Curseur avancé, pulses anciens perdus	Correctif à venir (curseur gelé si tronqué)	Ouvert
Collecte OTX de 200 pages : ReadTimeout après 17 min	Toute la collecte annulée	Correctif à venir (enregistrement page par page)	Ouvert
« NVD sans clé » affiché même avec une clé	Diagnostic trompeur	Message conforme à la configuration	Ouvert
TAXII_AUTH en double dans .env	Fonctionnement fragile	Doublon supprimé	Résolu
1 640 plages CIDR RedEye rejetées	Information perdue	Type « réseau » au backlog M8	Suivi

6. Métriques qualité

Indicateur	Valeur	Seuil
Couverture pytest (CI)	94 % (3.12) · 93 % (3.14)	≥ 80 %
Tests passants (CI, .env.example en place)	444 / 444 (+ 4 réseau)	100 %
Tests passants (Kali, .env en place)	442 / 442 (6 ignorés)	100 %
Conformité ruff	OK (181 fichiers)	100 %
mypy --strict	OK (78 fichiers)	0 erreur
Scénario SOC sur données réelles	48 / 48 (local et CI)	100 %
Commits fusionnés dans main (soirée)	1 (595d425)	—
Nouveaux tests	6	—

7. Prochaine session

1. **Correctifs de collecte** : curseur OTX gelé si la collecte est tronquée, enregistrement page par page au lieu du tout-ou-rien, message NVD conforme à la configuration.
2. **Trancher l'ADR-014** (recommandation A + B + C) : sans EPSS, 0 CVE en P0 ; avec, 495.
3. **Préproduction VPS UE** avec l'image publiée, SSL Labs ≥ A, 7 jours de collecte → clôture de M7.
4. Ouvrir **M8 « Detection & Correlation »**, avec au backlog le type « plage réseau » (CIDR) et l'export en flux.